

Vulnerability Assessment Report

Assessment Overveiw

Target Website - testphp.vulnweb.com

Assessment Type -Read-only vulnerability analysis

Tools Used - Nmap, OWASP ZAP, Browser DevTools

Conducted By - Hema Shree

Date - May 2026

Findings

Network Filtering / Firewall Protection

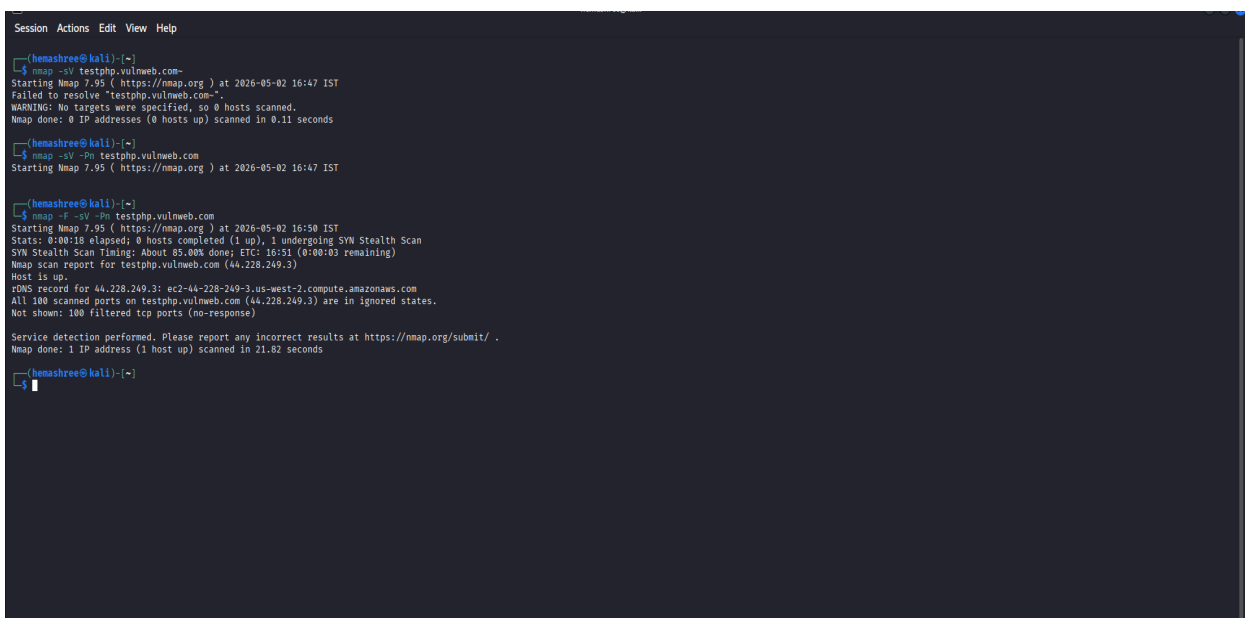
The scan performed using Nmap showed that all tested ports are filtered.

This indicates the presence of a firewall protecting the system. Severity:

Low

Recommendation:

Maintain firewall configuration and regularly monitor traffic.



```
Session Actions Edit View Help

(hemashree@kali)~$ nmap -v testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 16:47 IST
Failed to resolve "testphp.vulnweb.com".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.11 seconds

(hemashree@kali)~$ nmap -v -p- testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 16:47 IST

(hemashree@kali)~$ nmap -F -v -p- testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 16:50 IST
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 85.00% done; ETC: 16:51 (0:00:03 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up.
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 100 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 100 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.82 seconds

(hemashree@kali)~$
```

Figure 1 : Nmap scan output showing filtered ports

Web Application Vulnerabilities

1. Absence of Anti-CSRF Tokens

Description:

The application does not implement Anti-CSRF tokens, making it vulnerable to Cross-Site Request Forgery attacks.

Risk:

Attackers can perform unauthorized actions on behalf of authenticated users.

Severity: Medium

Recommendation:

Implement CSRF tokens in all sensitive forms and requests.

2. Content Security Policy (CSP) Header Not Set

Description:

The application does not define a Content Security Policy header to control resource loading.

Risk:

Increases risk of Cross-Site Scripting (XSS) attacks.

Severity: Medium

Recommendation:

Configure a strong Content Security Policy header.

3. Cookie without SameSite Attribute

Description:

Cookies are set without the SameSite attribute.

Risk:

Cookies may be sent with cross-site requests, increasing CSRF risk.

Severity: Low

Recommendation:

Set SameSite attribute to Strict or Lax.

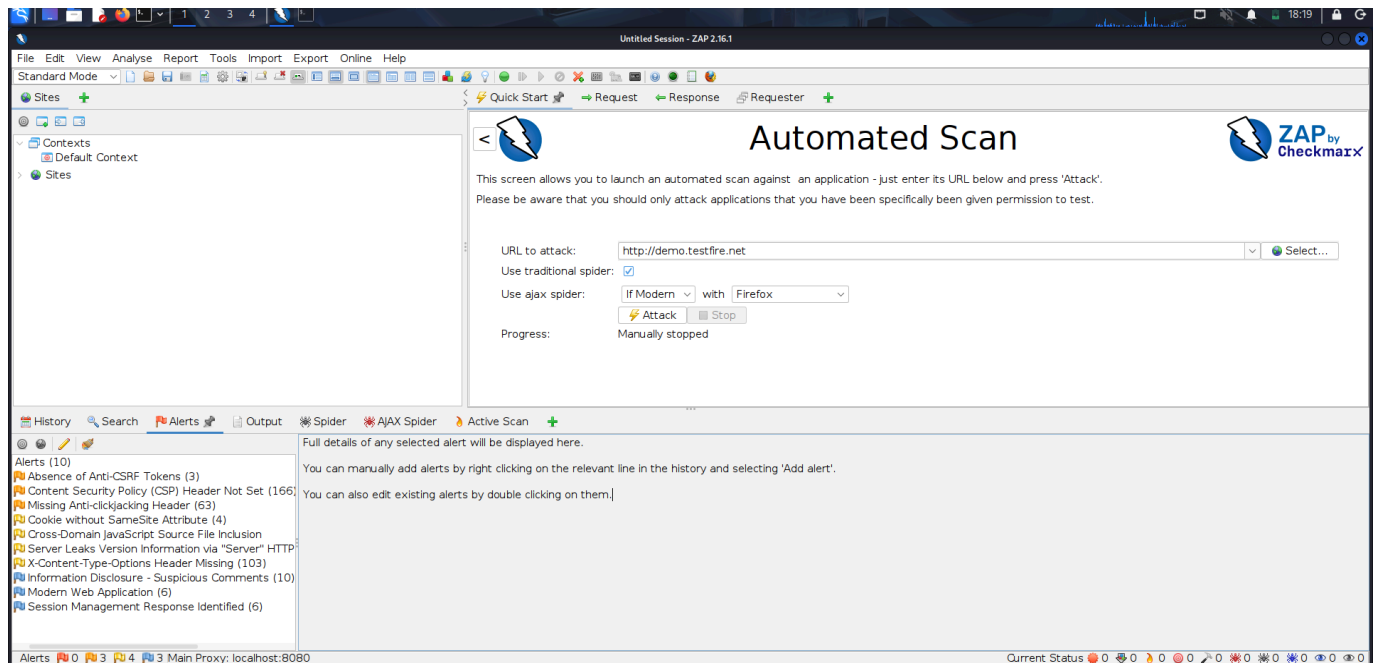


Figure 2: OWASP ZAP alert showing vulnerability

1.Absence of Anti-CSRF Tokens

Absence of Anti-CSRF Tokens

Description:

The web application does not implement Anti-CSRF (Cross-Site Request Forgery) tokens in its forms or requests. This means that requests sent by users are not properly validated to ensure they originate from the legitimate application.

Risk:

An attacker can trick a logged-in user into performing unintended actions (such as submitting forms or changing data) without their knowledge.

Severity:

Medium

Recommendation:

Implement Anti-CSRF tokens in all sensitive forms and requests. These tokens should be unique per session and validated on the server side.

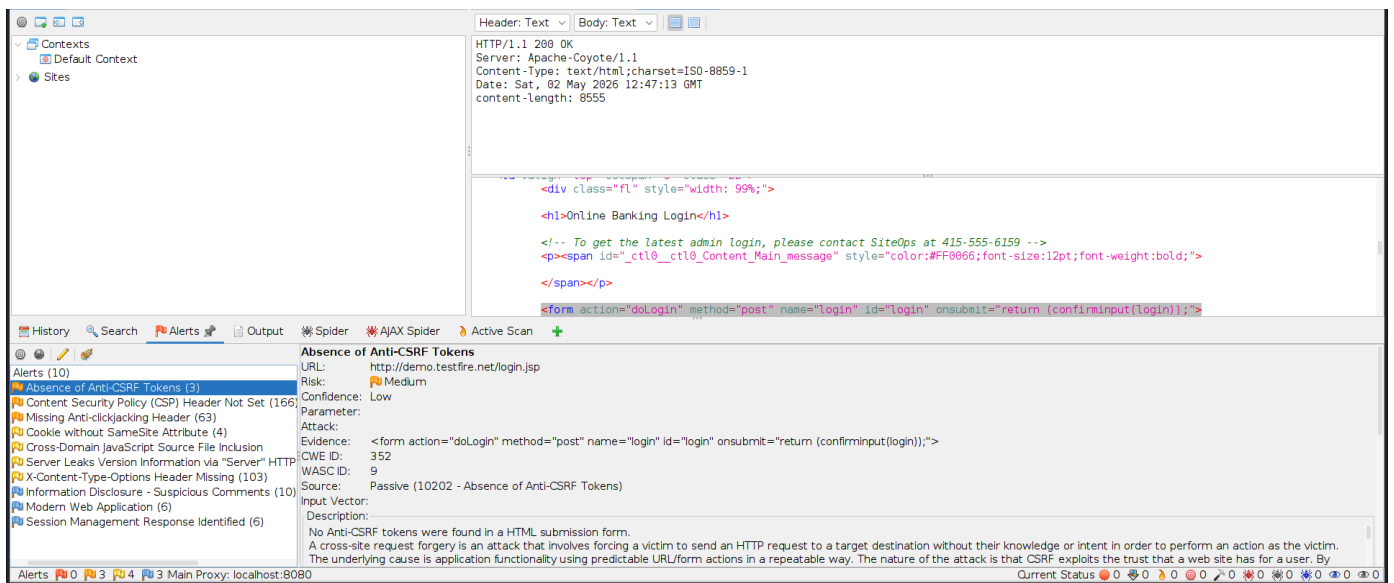


Figure 3: OWASP ZAP alert showing absence of Anti-CSRF protection

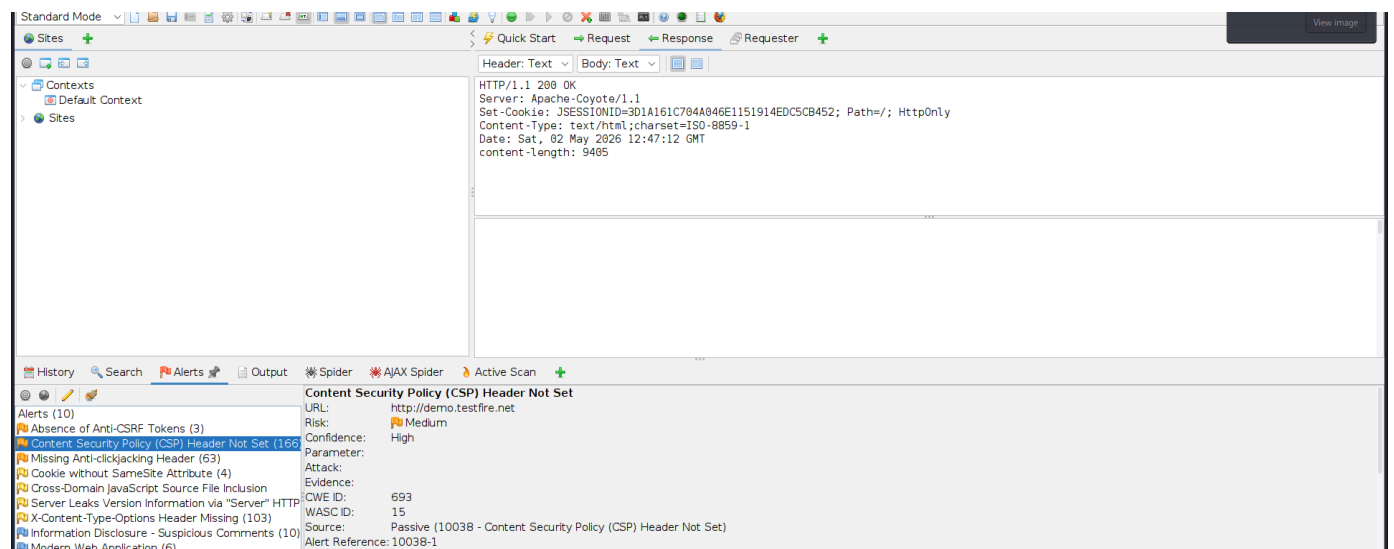


Figure 3: OWASP ZAP alert showing Content security policy Header Not set

Conclusion

The security assessment identified multiple vulnerabilities in the web application, including missing security headers and lack of CSRF protection. While no critical vulnerabilities were found, the presence of these issues can increase the risk of attacks such as Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF).

It is recommended that the identified vulnerabilities be addressed promptly to improve the overall security posture of the application.

Recommendations

- Implement Anti-CSRF tokens for all forms
- Configure Content Security Policy (CSP)
- Add security headers like X-Frame-Options and X-Content-Type-Options
- Use secure cookie attributes (SameSite, HttpOnly, Secure)
- Regularly perform vulnerability assessments